A Five-Pillar Federal AI Governance Framework: Substrate, Lineage, and Gaps

Governance is a property of the deployment substrate, enforced by the architecture and witnessed by 360-degree evidence — never a property of the policy document.

The five pillars below — (1) governance/security/privacy baked in, (2) assumed breach, (3) no single point of failure, (4) zero trust throughout, (5) 360 accountability — together define the smallest set of architectural commitments that produce a federally-defensible AI deployment in May 2026. Each pillar traces to a durable federal control architecture; each generates evidence-grade artifacts; each contains genuinely new requirements that current frameworks have not yet specified. The Mythos / Glasswing / Mercor incident chain of March–April 2026 functions as the empirical anchor: it is the first public AI supply-chain compromise to fail across all five pillars simultaneously, and its forensic reconstruction is referenced throughout.

This dossier is built from primary federal sources (NIST, OMB, CISA, NSA, DoD CIO, Treasury, GSA, federal courts) supplemented by primary international standards (ISO/IEC 42001, EU AI Act, GDPR), primary research (RAND, Carlini et al., OX Security), and authoritative trade reporting (Bloomberg, TechCrunch, The Information, Federal News Network, FedScoop). Where May 2026 status differs from older drafts or rescinded memoranda, the report is explicit. The synthesis section identifies the five-by-five interaction matrix and the design decisions a v1 framework will need to make.

Pillar 1 — Governance, security, and privacy baked in

Definition and federal standards lineage

Pillar 1 holds that governance, security, and privacy must be properties of the system as engineered, not the documents written about it. Three sublineages converge: **secure-by-design** (CISA white paper April 2023, RSA Pledge May 8 2024 with seven goals BeyondTrust and 250+ signatories by late 2025), **privacy-by-design** (Cavoukian's 1990s seven principles Wikipedia → GDPR Article 25 DPO Consulting → NIST Privacy Framework 1.0 January 2020 National Institute of Standards and → PFW 1.1 IPD April 2025), and **systems security engineering** (NIST SP 800-160 Vol 1 Rev 1 November 2022; Vol

2 Rev 1 December 2021). The AI-specific spine is **NIST SP 800-218 SSDF v1.1** (February 2022) NIST CSRC extended by **SP 800-218A** (July 2024, the AI/foundation-model profile) NIST and the joint **CISA / NCSC-UK Guidelines for Secure AI System Development** (November 2023, 23 international cosignatories).

Existing federal control architecture

The SSDF practice groups — Prepare the Organization (PO), Protect the Software (PS), Produce Well-Secured Software (PW), Respond to Vulnerabilities (RV) — comprise about 42 outcome-based tasks. SP 800-218A modifies PW.3 to require **integrity confirmation of training, testing, fine-tuning, and aligning data**, NIST treating data poisoning as a first-class SDLC risk. SP 800-160 Vol 1 Rev 1 specifies system lifecycle processes mapped to ISO/IEC/IEEE 15288:2015. CSRC The Privacy Framework's five Functions (Identify-P, Govern-P, Control-P, Communicate-P, Protect-P) provide the privacy-engineering core; **PFW 1.1 IPD adds Section 1.2.2 specifically addressing AI privacy risks** (data reconstruction, prompt injection, membership inference). Hunton FICAM, anchored in HSPD-12 / FIPS 201, supplies the identity substrate; OMB M-19-17 modernized it around NIST SP 800-63-3/-4.

The governance backbone is **OMB M-25-21 (April 3, 2025)**, GitHub +2 which rescinded M-24-10 Inside Global Tech MIstrategies and consolidated rights-impacting and safety-impacting AI into a single **"high-impact AI"** category. Brookings M-25-21 mandates a Chief AI Officer in every CFO Act agency, Governmentcontractslawblog Brookings an AI Governance Body, Inside Global Tech public AI use-case inventories, and seven minimum risk-management practices for high-impact AI Homeland Security Digitalgovernmenthub — pre-deployment impact assessment, real-world performance testing, independent evaluation, ongoing monitoring with periodic human review, adequate human training, public consultation, plain-language documentation. The hard deadline of **April 15, 2026 to bring high-impact AI into compliance or terminate** Homeland Security Brookings is categorically new in federal IT — historically, FISMA accepted POA&Ms; M-25-21 requires discontinuance.

AI-specific applications and gaps

What's covered: SSDF AI Profile (PW.3 data integrity), CISA/NCSC four-phase AI lifecycle (secure design / develop / deploy / operate), NSA "Deploying AI Systems Securely" (April 15, 2024) with hardware-isolated weight storage in Highly Restricted Zones, JCDC.AI Cybersecurity Collaboration Playbook (January 14, 2025), CISA CAIO governance under M-25-21, and ISO/IEC 42001 AIMS Annex A controls (38 across nine categories).

What's not: there is **no federal mandate for AIBOMs, model cards, datasheets-for-datasets, or pre-deployment evaluation registration**. CycloneDX ML-BOM 1.5 (June

2023) Medium and SPDX 3.0 AI/Dataset profiles exist but are voluntary. The CISA SBOM-for-AI Tiger Team has produced minimum-AIBOM-field proposals GitHub but no normative federal guidance. **"Governance by design"** as an architectural primitive appears in no federal document by that name; the closest analogs are NIST AI RMF GOVERN and ISO 42001 Annex A.5. Differential-privacy parameters are measured (NIST SP 800-226, 2025) but not prescribed by data sensitivity tier. Training data provenance has no SLSA-equivalent regime. **OMB M-26-05 (February 2026) rescinded M-22-18 and M-23-16**, Inside Government Contracts eliminating the centralized CISA Common Form attestation, leaving secure-development attestation as agency-tailored — a genuine fragmentation risk that v1 frameworks must accommodate.

Architectural control primitives

The deployable Pillar 1 substrate combines: PIV/CAC plus phishing-resistant FIDO2 for human identity per OMB M-22-09; Non-Person Entity credentialing per the DoD ICAM Reference Design; U.S. Department of Defense SSDF practice tasks operationalized in build pipelines; SBOM (CycloneDX/SPDX) GitHub plus AIBOM (CycloneDX ML-BOM) at release; reproducible builds plus signed artifacts via SLSA + Sigstore + in-toto; AquilaX threat models that combine MITRE ATT&CK with **MITRE ATLAS**; selectively applied SP 800-160 Vol 2 cyber-resiliency techniques (Substantiated Integrity for model signing, Diversity for ensembles, Non-Persistence for ephemeral inference, Segmentation, Deception via canary tokens in training data); PFW Functions backed by mandatory PIA under E-Gov Act §208 The White House and OMB M-03-22, U.S. Department of Health and Hu with Disassociated Processing techniques (differential privacy, federated learning, MPC, HE) for sensitive workloads; and the M-25-21 governance substrate (CAIO, AI Governance Body, AI Use Case Inventory, AI Impact Assessment as gating artifact).

Evidence artifacts

The artifact set ladders from organizational governance through software through model/data through operations: AI Compliance Plan, CAIO charter, AIMS documentation, Public AI Use Case Inventory, AI Impact Assessment, PIA, threat model, real-world performance test report, pre-deployment red-team report, SBOM, AIBOM, build provenance (SLSA, in-toto), CVE records with proper CWE/CPE, model card, datasheet for datasets, training-data provenance manifest, differential-privacy parameter disclosure, PIV issuance audit, AAL record, NPE/agent credential inventory, continuous monitoring report, JCDC.AI voluntary incident reports, public notice and opt-out disclosures, waiver records, and termination records for failed-compliance systems.

Critical view — new versus restated

Genuinely new for AI: training-data integrity confirmation as a first-class SDLC task; the code/data boundary blurring (prompt injection has no clean SQL-injection analog); the M-25-21 hard "comply or terminate" model; the cross-functional CAIO role; mandatory public AI use-case inventory; MITRE ATLAS as a recognized threat domain; "real-world performance testing" closer to FDA SaMD than to FISMA assessment. **Restated**: most "secure-by-design for AI" guidance is SDLC security re-skinned; AI Impact Assessment structurally mirrors PIA; AI use-case inventory is a public-facing FISMA system inventory; AI Governance Body is an SP 800-39 Risk Executive Function pointed at AI; ISO 42001 AIMS is Annex SL applied to AI. The honest claim of newness lives in: AIBOM standardization, agent/NPE identity, pre-deployment evaluation registration, the phrase "governance-by-design" as architectural primitive, continuous attestation post-M-26-05, and cross-pillar evidence integration (no single artifact today combines PIA + AIIA + Model Card + SBOM + AIBOM + provenance + 3PAO).

Pillar 2 — Assumed breach

Definition and federal standards lineage

Pillar 2 inverts defense-in-depth's premise: the perimeter is presumed already compromised; design optimizes for **containment, blast-radius reduction, detection, and response** rather than prevention alone. The doctrine moves from Microsoft's mid-2010s Red Team practice (Bret Arsenault, codified in BizTech 2021) BizTech Magazine → NSA's *Embracing a Zero Trust Security Model* (February 2021) → NIST SP 800-207 §2 (August 2020) nist → **OMB M-22-09 (January 26, 2022)**, which states: "the Federal Government can no longer depend on conventional perimeter-based defenses." Illumio DoD codifies it as two of seven guiding principles in the Zero Trust Reference Architecture v2.0 U.S. Department of Defense (July 2022): **"Assume a hostile environment"** and **"Presume breach."** Microsoft Learn DTIC

Existing federal control architecture

CISA's **Zero Trust Maturity Model 2.0 (April 2023)** institutionalizes assume-breach across five pillars, three cross-cutting capabilities, and four maturity stages (Traditional → Initial → Advanced → Optimal). Cisco +2 It is explicit that "any component can be compromised, including monitoring tools" The White House — but it equally explicitly excludes AI/ML methodologies from scope, Scribd a structural gap. DoD ZT Strategy (November 2022) targets full Target-level capabilities by FY27 Cisco and Advanced by FY32 across 152 capabilities; Xage Security **DISA Thunderdome was validated at 152/152 in April 2025**, DefenseScoop two years ahead of schedule, with Navy Flank Speed and a third "Ford Zero" similarly validated. Fedgovtoday **DoD ZT Strategy 2.0**

(announced ~March 2026 by Randy Resnick at DefenseTalks) DefenseScoop extends to OT DefenseScoop (FY30/FY33) and weapon systems (~FY35) but, as of May 2026, has not been confirmed publicly released.

The AI-specific assume-breach stack: NSA-led joint **"Deploying AI Systems Securely"** (April 15, 2024) CISA which mandates "adopt a ZT mindset, which assumes a breach is inevitable or has already occurred" Defense Defense and recommends weights stored in Highly Restricted Zones with HSM-backed keys; **"Best Practices for Event Logging and Threat Detection"** (August 21, 2024) CISA requiring JSON / ISO 8601 / hardened SIEM with retention covering 70–200 day dwell times and 18-month detection lag; Defense the **CISA JCDC AI Cybersecurity Collaboration Playbook** CISA (January 14, 2025); and the **NSA AI Data Security CSI** (May 22, 2025). Davis Wright Tremaine

AI-specific applications

The five canonical AI assume-breach assumptions: **(a)** assume model weights leak — the RAND *Securing AI Model Weights* report (Nevo et al., May 2024) identifies 38 attack vectors and defines five Security Levels SL1–SL5 keyed to attacker tier; RAND **(b)** assume training data is poisoned — Carlini et al. *Poisoning Web-Scale Training Datasets is Practical* (IEEE S&P 2024) showed arXiv arXiv split-view and frontrunning attacks for ~$60 against LAION-400M; **(c)** assume inference endpoints are compromised — OWASP LLM Top 10 (2025) keeps prompt injection at #1 Invicti and elevates supply chain to #3; Trydeepteam **(d)** assume agent credentials are stolen — OWASP LLM06:2025 *Excessive Agency*; **(e)** assume contractor/third-party access is breached — the dominant 2025–2026 attack vector, exemplified by Mercor.

Mythos / Glasswing / Mercor incident chain

This is the canonical worked example. The cascade: **TeamPCP** compromised Trivy's `aqua-bot` PAT via a `pull_request_target` workflow vulnerability and rewrote GitHub Action v0.69.4 with credential-harvesting payloads (late February / mid-March 2026). LiteLLM's CI/CD ran the compromised Trivy action with unpinned references and exfiltrated its `PYPI_PUBLISH` token; StrikeGraph **TeamPCP published malicious LiteLLM 1.82.7 and 1.82.8 to PyPI on March 27, 2026, live for ~40 minutes**. Second Talent +2 LiteLLM is downloaded ~95–97 million times per month StrikeGraph and present in ~36% of cloud environments; The Next Web +3 Mandiant's Charles Carmakal estimated 1,000+ SaaS environments affected. compliancehub Stateofsurveillance **Mercor** — a $10B AI training-data startup serving OpenAI, Anthropic, Meta, Google — auto-pulled the malicious package and lost ~4 TB to a Lapsus$ / TeamPCP exfiltration StrikeGraph via Tailscale: Repello 939 GB source code, StrikeGraph 211 GB user database, ~3 TB videos / KYC / passports / facial biometrics,

internal Slack and ticketing, Tailscale config, compliancehub contractor PII for ~40,000 contractors. StrikeGraph Concurrently, the anonymous "DeepDelver" Substack alleged that **Delve Technologies** — which had certified LiteLLM StrikeGraph and BerriAI — had templated 494+ SOC 2 / ISO 27001 / HIPAA reports; **Y Combinator removed Delve from its directory on April 3, 2026**. compliancehub

The Anthropic dimension closed the chain. On **April 7, 2026**, Anthropic announced **Project Glasswing**, restricted preview access to ~40 organizations for **Claude Mythos**, claimed to "surpass all but the most skilled humans at finding and exploiting software vulnerabilities." Inc Tom's Hardware Within ~14 hours, a private Discord group reconstructed Anthropic's URL/naming conventions from the Mercor leak, Tom's Hardware used a member's legitimate evaluation credentials BeInCrypto at an Anthropic third-party vendor, and gained ongoing access to Mythos Preview BeInCrypto by URL guess plus walk-in — no exploit, no zero-day, no social engineering. Arnav Anthropic confirmed access via "the third-party vendor environment." Inc

The assumptions that failed across five distinct trust boundaries: pinned-and-signed dependencies were not enforced (Trivy → LiteLLM); SOC 2 attestation substituted for independent verification (Delve → LiteLLM → Mercor); contractor evaluation accounts were treated as low-risk despite broad scope (Anthropic vendor); URL secrecy was treated as a security boundary (Mythos endpoint); and the effective attack surface of "40 vetted orgs" was multiplied by each org's own vendor chain.

Architectural control primitives

Containment ladder for AI workloads: standard containers (insufficient) → gVisor (user-space kernel, 10–30% I/O overhead, Northflank used by Modal and GKE Sandbox) Substack → Kata Containers → **Firecracker** (~125ms cold-start, ~5 MiB overhead, Northflank used by Lambda, Fargate, SoftwareSeni E2B, Vercel Sandbox) → WebAssembly + WASI (capability-bounded). For agents, the frontier control is **what the agent can call** — tool-use allowlists, MCP scope tokens, OAuth-scoped credentials, human-in-the-loop confirmations, per-tool risk classification, and budget caps (LLM10 Unbounded Consumption). NSA "Deploying AI Systems Securely" mandates the capability "to disconnect all inbound connections to the AI models and systems in case of a major incident" Defense — kill-switches are now table stakes. AI-specific detection: anomalous inference detection (Lakera, Protect AI Rebuff, NVIDIA NeMo Guardrails), prompt-injection detection, model-extraction detection (query rate-limiting, watermarking, distillation-pattern fingerprinting), training-data exfiltration DLP, and continuous file-integrity monitoring of weight blobs in HRZ.

Evidence artifacts

Tabletop AARs in CISA CTEP / HSEEP format (no AI-specific CTEP exists in CISA's public

catalog as of May 2026 despite the JCDC.AI exercises at Microsoft June 2024 and Scale AI Industrial Cyber late 2024); Infosecurity Magazine incident response logs per the August 2024 joint event-logging guide; CISA breach drill artifacts equivalent to DoD PfMO Purple Team Reviews; DAU JCDC voluntary information-sharing artifacts under Cybersecurity Information Sharing Act of 2015 protections; Freeman Mathis & Gary CISA AIBOMs; RAND SL1–SL5 weight-security benchmark assessments.

Critical view

Genuinely new for AI: weight as a single point of catastrophic loss (a one-shot capability transfer with no clean federal-doctrine analogue); the probabilistic, non-deterministic enforcement boundary (OWASP LLM01:2025: "it is unclear if there are fool-proof methods of prevention"); OWASP training data as a long-fuse attack vector operating on release-cycle timescales beyond standard SOC windows; agent excessive agency creating credential blast-radius interactions that ZT's per-session tenet handles only partially; embedding/semantic anomaly detection as a new telemetry class. **Restated**: most assume-breach controls are generic ZT applied to AI assets — micro-segmentation, MFA, least-privilege, encryption, centralized logging, behavioral analytics, kill-switch, supply-chain risk per SP 800-161 Rev 1, tabletops per HSEEP. **Net read**: roughly 75% restated ZT controls applied to AI assets + 25% genuinely new requirements (weight-tier security levels, probabilistic-input defense, agent-capability scoping, dataset provenance, embedding-drift detection, AI BOM/model attestation).

Pillar 3 — No single point of failure

Definition and federal standards lineage

Pillar 3 demands resilience, redundancy, and the absence of concentration risk in the deployment substrate. Its lineage runs through **NIST SP 800-160 Vol 2 Rev 1** (December 2021) NIST CSRC — 14 cyber-resiliency techniques NIST CSRC explicitly including **Diversity** as the anti-monoculture technique, plus Redundancy, Segmentation, Coordinated Protection, and Adaptive Response — through **NIST SP 800-34 Rev 1** (May 2010, current) NIST CSRC for contingency planning (BIA, RTO, RPO, MTD), **NIST SP 800-161 Rev 1 upd1** (November 2024) for cybersecurity supply-chain risk management with the new **SR family in 800-53 Rev 5**, ScienceDirect and **EO 14028** (May 12, 2021) for the SBOM lineage carried forward through NTIA July 2021 minimum elements Federal Register and the **CISA 2025 Minimum Elements for an SBOM NPRM** (August 22, 2025).

Existing federal control architecture

NIST 800-53 Rev 5 supplies the operational controls: CP family (CP-2 through CP-13 for contingency, alternate sites, backup, recovery), ScienceDirect +2 SR family (SR-2 SCRM plan, SR-3 controls, SR-4 provenance, SR-6 supplier assessments, SR-9 tamper detection, SR-11 component authenticity), Isora GRC AC-5 separation of duties, AC-3(2) dual authorization, and CM-3 configuration change control. **HSPD-20 / NSPD-51** (May 2007) anchors continuity of operations at the policy level. The financial-sector overlay is materially more mature than the cybersecurity one: **Treasury's "Financial Services Sector's Adoption of Cloud Services"** (February 8, 2023) identified six concentration-related challenges; the **Interagency Guidance on Third-Party Relationships** (June 6, 2023) — FRB SR 23-4, OCC Bulletin 2023-17, FDIC FIL-29-2023 Hunton — established a unified third-party lifecycle with explicit concentration-risk consideration; **FSOC's 2023 and 2024 Annual Reports** flagged AI as a financial-stability vulnerability citing "concentration among vendors developing models, providing data and providing cloud services."

AI concentration risk taxonomy

Six distinct, partially correlated concentration domains are established in primary data. **Foundation model**: per Menlo Ventures' 2025 enterprise survey, Anthropic ~40% of enterprise LLM spend, OpenAI ~27%, Google ~21% Menlo Ventures — combined top-3 ~88%, with cross-shareholdings (Microsoft–OpenAI exclusivity, Brookings AWS and Google as Anthropic backers) Computer Weekly deepening it. **Compute**: per Epoch AI, ~15M H100-equivalents globally; Epoch AI xAI Colossus 2 alone targets 1.4M H100e in 2026; Epoch AI Microsoft ~500K H100e, Google >1M H100e largely TPUs; Epoch AI NVIDIA's data-center revenue ~$111B over 10 quarters; Epoch AI TSMC's CoWoS advanced packaging is the chip-supply bottleneck. Epoch AI **Inference**: AWS Bedrock / Azure OpenAI / Google Vertex; switching foundation model often forces switching cloud. **Training data**: most frontier models trained on Common Crawl-derived corpora (C4, RefinedWeb, RedPajama-V2, FineWeb, DCLM-Baseline). **Evaluation**: CAISI plus a thin top-of-pyramid (METR, Apollo Research, Redwood, RAND, MITRE). **Framework/tooling**: PyTorch + HuggingFace, OpenAI Chat Completions API as de facto standard, LangChain / LlamaIndex orchestration, CUDA still dominant.

Recent incident lessons

Three concentration-failure events frame the v1 framework. **CrowdStrike Channel File 291 (July 19, 2024)** crashed ~8.5M Windows endpoints from a 21-vs-20 input-field mismatch causing a kernel out-of-bounds read; Parametrix estimated $5.4B direct loss to Fortune 500 ex-Microsoft; the case reactivated the Geer-Schneier monoculture argument from CCIA's 2003 *CyberInsecurity: The Cost of Monopoly*. Fermigier **AWS US-EAST-1 (October 19–20, 2025)** was a latent race condition in DynamoDB's automated DNS management, InfoQ ~15-hour disruption, Medium CyberCube

estimated insured loss up to $581M; Medium demonstrated that "regional isolation is a myth" Medium when global control planes anchor to US-EAST-1. **Azure Front Door (October 29, 2025)** — third Azure October incident — was an inadvertent tenant configuration change not caught by buggy protection mechanisms, cascading to M365, Teams, Xbox, Entra, and downstream tenants. Sangfor Technologies **Azure West US (February 7–8, 2026)** added cascading control-system failure preventing automated transfer to generators. Microsoft Azure Composite lesson: AI inference on a single hyperscaler region inherits all of these failure modes, and AI auto-update channels (model versions, guardrail policies) can replicate the CrowdStrike pattern at AI scale.

Architectural control primitives

The Pillar 3 substrate combines **multi-model abstraction** (LiteLLM, LangChain, OpenAI-compatible endpoints as switching primitives, ONNX for serialization, vLLM/TGI for self-hosting); **AIBOM** (CycloneDX ML-BOM 1.5, SPDX 3.0 AI/Dataset profiles, CISA SBOM-for-AI Tiger Team minimum fields, GitHub OWASP AIBOM Generator); OWASP **SLSA-Sigstore-in-toto provenance** (SLSA L1-L3 build levels, ActiveState Sigstore keyless OIDC signing via Fulcio + Rekor transparency log, AquilaX in-toto ITE-6 attestation envelopes, AquilaX GitHub Actions `actions/attest-build-provenance`); AquilaX **separation-of-duties and dual control** (AC-5, AC-3(2), AC-6 with AC-6(9) privileged-function logging, threshold cryptography for model-release keys); **federated/decentralized AI** (NIST PETs Testbed and PPFL program, US-UK PETs Prize Challenges); and **diversity-as-defense** (ensemble methods, model rotation, multi-vendor evaluation triangulation, A/B canary deploys).

Evidence artifacts

AIBOM (CycloneDX ML-BOM 1.5+); SLSA Provenance Attestation in in-toto ITE-6 envelope; SLSA SBOM; ISCP per SP 800-34 Rev 1 with AI-specific RTO/RPO/MTD; ScienceDirect BIA documenting AI dependencies (mission processes degrading at 1h/4h/24h/7d outages); cyber-resiliency analysis mapping each of 14 SP 800-160 Vol 2 techniques to deployed controls; C-SCRM plan per SP 800-161 Rev 1 with AI supply-chain entries; TPRM program per FRB SR 23-4 / OCC 2023-17; Federal Register **concentration risk register** identifying any vendor exceeding an organization-defined share; tested failover runbook with exercise records within 12 months covering model-provider, inference-cloud, and eval-provider failover; SoD matrix and multi-party authorization records for production deployment.

Critical view

The federal architecture for resilience and supply-chain integrity is **broad and mature for traditional IT but not yet operationalized for AI**. Three structural gaps are

dispositive: foundation-model concentration (~88% top-3), compute concentration (NVIDIA + TSMC CoWoS chokepoints), and inference-cloud concentration substantially exceed anything federal cybersecurity standards were designed to handle. **Federal financial-sector guidance has clearer concentration-risk language than federal cybersecurity guidance** — Treasury Cloud 2023 and FSOC 2024 use the word; Pifsinternational NIST 800-53 / 800-160 / 800-161 do not. The 2025 EO churn and early-2026 OMB rescissions of M-22-18 / M-23-16 weakened centralized supply-chain attestation at exactly the moment AI supply-chain risk surged. The defensible v1 posture is **layered**: L1 table-stakes (AIBOM, SBOM, ISCP, C-SCRM plan, SoD matrix); L2 resilience-engineered (SLSA L2+ with Sigstore, multi-region inference, multi-model abstraction with tested failover, concentration risk register); L3 federated/distributed (architecturally and corporately independent multi-vendor diversity, multi-cloud, PPFL where data sovereignty applies, threshold cryptography over release keys). Cautions: "diversity" becomes checkbox theater when two providers share underlying compute or cross-shareholders, and produced-from-binary AIBOMs face the same ground-truth problems as binary SBOMs.

Pillar 4 — Zero trust throughout

Definition and federal standards lineage

Pillar 4 applies "never trust, always verify" to humans, services, and **AI agents**. The standards spine is **NIST SP 800-207** (August 2020, the seven tenets and PE/PA/PEP model); **SP 800-207A** (September 2023, identity-centric segmentation in cloud-native multi-cloud, which says explicitly "policies have to be defined based on the assumption that the attacker is already inside" NIST and shifts focus to identity infrastructures like SPIFFE); NIST CSRC NIST CSRC **NIST SP 1800-35** (final June 2025, 19 reference implementations from 24 industry collaborators); NCCoE NIST CSRC **OMB M-22-09** (January 26, 2022, the FY24 deadline) extended via NSM-8 to DoD/IC; **CISA Zero Trust Maturity Model 2.0** (April 2023) with five pillars × four maturity stages × three cross-cutting capabilities; Cisco CISA **DoD Zero Trust Strategy** (November 2022, FY27 Target / FY32 Advanced, 152 capabilities, with **DTM 25-003** effective July 17, 2025 Whs codifying the EXCOM and Chief ZT Officer); and the **NSA Zero Trust Implementation Guideline Primer** (January 8, 2026) defining five execution phases.

Existing federal control architecture

The seven 800-207 tenets compose to: **all data sources and computing services are resources**; CISA **all communication is secured regardless of network location**; **per-session access**; Centers for Medicare & Medicaid S CDSE **dynamic policy** including

identity, device, and behavioral attributes; **continuous integrity and posture monitoring of all assets**; **dynamic, strictly enforced authentication and authorization**; Security Boulevard **maximum information collection** to improve posture. The Policy Decision Point (PE + PA) and Policy Enforcement Point are bifurcated across a control plane and data plane. NIST Trust algorithm variations — criteria-based AND, score-based weighted, singular per-request, contextual with history — are the configuration knobs. Implementation status as of May 2026: most FCEB agencies missed the FY24 deadline per the January 29, 2025 CISA ZTA Implementation Report; DoD has three solutions validated 152/152 (Thunderdome, Flank Speed, Ford Zero), Fedgovtoday but agent-specific extensions await Strategy 2.0.

ZTA applied to AI — the new edges

Every AI control-plane edge becomes a policy-evaluated transaction: every inference call, every agent action, every model-to-model call, every tool invocation, every retrieval, every model-weight read, every training-data access. Today these edges are largely unenforced — model serving stacks (Triton, vLLM, TGI, Ollama) typically expose unauthenticated HTTP/gRPC; OAuth tokens are long-lived; A2A protocol (Google) has no normative auth section; vector indexes index across tenants; data-lake access is granted at job rather than row level. The architectural answer is fresh authorization per agent action via short-lived scope-bound tokens (RFC 8693 token exchange with `act` claims for delegation provenance), Gravitee agent-to-agent mTLS with SPIFFE identities, and tool invocation gated on OAuth-scoped grants per tool.

The CAISI AI Agent Standards Initiative — February 17, 2026

This is the single most important new federal artifact for Pillar 4. Three pillars: industry-led standards facilitation (US leadership in ISO/IEC JTC 1/SC 42 and ITU); Lab Space community-led open-source protocol development (with NSF, naming MCP and A2A as interoperability baselines, targeting an **AI Agent Interoperability Profile by Q4 2026**); Lab Space foundational research in agent security and identity. Lab Space Key deliverables to track: the **CAISI RFI on AI Agent Security** (Federal Register Docket NIST-2025-0035, Lab Space comments closed March 9, 2026); the **NCCoE Concept Paper "Accelerating the Adoption of Software and AI Agent Identity and Authorization"** (February 5, 2026, comments closed April 2, 2026), proposing adaptation of OAuth 2.0, OIDC, and SPIFFE/SPIRE to autonomous agents as distinct non-human identities; Lab Space sector listening sessions in healthcare, finance, education (April 2026); Bdemerson **SP 800-53 control overlays for single-agent and multi-agent systems** forthcoming. Lab Space Lab Space

MCP security review — the canonical AI ZT failure pattern

MCP is the empirical demonstration of "agent edge added without ZT controls catching up." The April 15–16, 2026 OX Security disclosure *The Mother of All AI Supply Chains* documented an architectural RCE in MCP STDIO across all official Anthropic SDKs (Python, TypeScript, Java, Rust), affecting 150M+ downloads, 7,000+ publicly accessible servers, ~200K vulnerable instances. OX Security Four exploit families: command injection via STDIO; via direct STDIO config with hardening bypass; via zero-click prompt-injection MCP config edit; and via marketplace poisoning (9 of 11 registries successfully poisoned with benign trial-balloon payload). OX Security OX issued 30+ responsible disclosures and 10+ High/Critical CVEs. OX Security **CVE-2026-30615 in Windsurf 1.9544.26** (CVSS 8.0 HIGH, GHSA-wj2m-jvpr-64cq, April 15, 2026) Feedly is the only true zero-click — prompt injection via attacker-controlled HTML modifies local MCP config and auto-registers a malicious STDIO server with no user interaction. Feedly The heyuan110.com report *MCP Security 2026: 30 CVEs in 60 Days* documented >30 CVEs January–February 2026, including a CVSS 9.6 RCE Heyuan110 Hacker News in mcp-remote (~437K downloads, CVE-2025-6514). Endor Labs analysis of 2,614 MCP implementations found 82% use FS operations prone to path traversal, 67% sensitive APIs vulnerable to code injection, 34% command-injection-susceptible APIs. Medium

The MCP Authorization Specification (revision 2025-06-18) now requires OAuth 2.1 + PKCE for HTTP-transport MCP servers using RFC 9728 Protected Resource Metadata + RFC 8414 Authorization Server Metadata + optional RFC 7591 DCR; Descope STDIO transport explicitly out of scope; Model Context Protocol token pass-through prohibited; server-to-server auth still out of scope. Stack Overflow Anthropic declined to modify the protocol architecture, citing STDIO behavior as "expected" — leaving sanitization to developers. OX Security **The Pillar 4 lesson**: MCP shifts the trust boundary to the config file and the registry, neither of which has a federation-grade integrity model.

Architectural control primitives

The deployable Pillar 4 substrate: **SPIFFE / SPIRE** workload identity (CNCF graduated; SPIFFE ID URI + X.509-SVID for mTLS or JWT-SVID for HTTP, default 1-hour TTL with auto-rotation, Substack node attestation via TPM PCRs / EC2 IID / k8s SAT, workload attestation by namespace/SA/image/UID, Travis Media Medium integrated into Istio, Istio Linkerd, Envoy SDS, AWS App Mesh, Consul); **microsegmentation** for AI training clusters (NVIDIA BlueField DPUs for encryption-at-NIC, segmented IB partitions, dedicated VRFs per training job) and inference fleets (per-tenant namespace + NetworkPolicy + sidecar mTLS, GPU-MIG, Cilium eBPF identity-aware policies, Tetrate / Istio Ambient Mesh L7); **confidential computing** (Intel TDX GA on Sapphire Rapids/Emerald Rapids, AMD SEV-SNP GA on Milan/Genoa, Google Cloud **NVIDIA H100 Confidential Compute GA on CUDA 12.4**, NVIDIA Developer multi-GPU + NVLink TEE

GA on Blackwell, end-to-end CPU TEE ↔ GPU TEE with remote attestation arXiv gating key release); **continuous authorization** (UEBA + ITDR, OPA/Rego, Cedar, AuthZEN-conformant PDPs, step-up auth for agent scope escalation); and **vendor agent-identity products** (Microsoft Entra Agent ID public preview 2026, Techzine Global Okta for AI Agents GA April 30 2026, AI Magicx HashiCorp Vault Enterprise SPIFFE auth, HashiCorp Auth0 Token Vault productizing RFC 8693 chains).

Evidence artifacts

PE/PA/PEP decision logs with subject, resource, action, signals consulted, trust score, policy ID, timestamp; SPIRE Server registration and SVID issuance logs; node and workload attestation reports (TPM PCRs, IIDs, SA token claims); confidential-computing remote attestation reports (Intel TDX quote, SEV-SNP report, H100 attestation) with verifier output before key release; OAuth/OIDC token issuance and refresh logs including RFC 8693 `act` -claim chains; MCP authorization events (discovery, DCR, scope grants, tool-call decisions, step-up); AuthZEN PDP audit; microsegmentation policy artifacts in Git; continuous-monitoring metrics (% east-west mTLS, % workloads with SVID < 1h, % workloads with no static cloud creds, anomaly-driven revocation counts); per-prompt classification and tenant entitlement decisions; MCP CVE inventory and patch evidence including marketplace provenance; delegation provenance records.

Critical view

The Pillar 4 thesis is **logically correct and operationally impractical at scale today**. Caveats: (1) the trust algorithm doesn't yet model AI agents well — separating malicious from benign behavioral drift in a stochastic agent is a research problem; (2) PE/PA/PEP performance budget is tight for high-QPS workloads, requiring hierarchical cached decisions in tension with "always verify"; (3) the MCP CVE record is genuine but interpreted overbroadly — most CVEs require attacker-controlled config or a malicious registry; treating MCP as Log4Shell-equivalent is overstated, treating it as trusted-by-default is exactly the anti-ZT pattern; (4) vendor agent-identity products (Entra Agent ID, Okta for AI Agents) are overlapping and not yet interoperable; CAISI's Initiative is the right intervention but interoperability is 12–18 months out; (5) DoD's 152/152 claim is meaningful but bounded — agents aren't yet in the 152, Strategy 2.0 not yet released; (6) CAISI has decoupled from prior-administration safety/RMF framing and emphasizes interoperability + security + dominance, National Institute of Standards an Federal News Network distinct from AI-RMF risk management Tech Policy Press — clients should hedge by tracking both. **The defensible v1 position**: compose existing primitives (SPIFFE + AuthZEN + RFC 8693 + MCP auth spec + TEEs) and design the evidence model to absorb whatever CAISI publishes through 2026–2027.

Pillar 5 — 360 accountability

Definition and federal standards lineage

Pillar 5 — the newest and most distinctive — holds that developer, deployer, contractor, vendor, regulator, and end-user all share auditable obligations that flow through a single evidence chain. As of May 2026, **no single U.S. statute or regulation allocates accountability across the full AI value chain**. The closest analogs are the **EU AI Act** (Regulation 2024/1689) provider/deployer split and Article 53 GPAI obligations operative since August 2, 2025; **NIST AI RMF GOVERN** (GV.RR roles and responsibilities, GV.PO policies, GV.SC supply chain, GV.RM risk management); **GDPR** controller/processor (Articles 4(7), 4(8), 24, 28); the **GPAI Code of Practice** finalized July 10, 2025; **FAR 52.244-6** flow-down for commercial items; and the **DFARS 252.204-7012 / 7021** chain culminating in CMMC 2.0 (32 CFR Part 170, final October 15, 2024, effective December 16, 2024). Pillsbury Winthrop Shaw Pittman

Existing accountability allocation frameworks

The EU AI Act's Article 3 distinguishes provider (places the system on the market) from deployer (uses under their authority); high-risk obligations (Articles 8–21) fall on providers; deployer obligations (Article 26) include using systems per provider instructions, assigning human oversight, monitoring, and informing affected persons. EU Artificial Intelligence Act Article 53 imposes four GPAI-provider duties: technical documentation under Annex XI, information to downstream providers under Annex XII, Union copyright-compliance policy, Arnold & Porter and public summary of training content using the Commission's July 2025 template; systemic-risk GPAI (Article 51, training compute >10^{25} FLOPs) adds Article 55 obligations. arXiv Article 88 enforcement vests in the AI Office; penalties up to 7% of global turnover. The Act explicitly contemplates "downstream provider becomes provider" via substantial fine-tune (more than one-third of original training compute) arXiv but **does not allocate accountability to compliance certifiers, contractor data labelers, or open-source gateways** — three of the five Mercor defendants.

The federal contractor flow-down architecture is currently: FAR 52.204-21 basic safeguarding; FAR 52.204-25 Section 889; DFARS 252.204-7012 (cyber-incident reporting, 72 hours, mandatory subcontract flow-down); Pivot Point Security DFARS 252.204-7021 (final September 10, 2025, effective November 10, 2025, phased over four years to November 10, 2028, O'Melveny requiring prime to verify subcontractor CMMC status before subaward); Inside Government Contracts and CMMC 2.0 levels L1 (FCI self-assessment), L2 (CUI third-party assessment by C3PAO), L3 (high CUI government-led DIBCAC). BDO DOJ's Civil Cyber-Fraud Initiative recovered $52M FY2025; O'Melveny with CMMC affirmations in SPRS as gating conditions, every non-

compliant invoice becomes a potential FCA case. Mondaq

Mercor — the canonical 360-accountability stress test

Ananthula et al. v. Mercor.io Corporation et al., No. 3:26-cv-03362 (N.D. Cal., filed April 21, 2026, by Hausfeld LLP and Hall Attorneys, P.C.) Hallattorneys is the first U.S. complaint to name, in a single theory of liability, defendants spanning five of the six 360-accountability roles: foundation-model developers (Doe AI Lab Defendants 1–10), open-source gateway vendor (Berrie AI / LiteLLM), compliance certifier (Delve Technologies), data-labeling contractor (Mercor.io), and indirectly the end users (worker plaintiffs and class members whose biometrics and HR files were exfiltrated). The 45-page, ten-count complaint pleads negligence, breach of implied contract, intrusion upon seclusion, FCRA, Illinois BIPA Hallattorneys (facial biometrics), Illinois AIVIA (only the second federal-court suit under the 2020 statute), ICFA, FDUTPA, unjust enrichment, and declaratory and Hallattorneys injunctive relief. The companion **White & Beltran v. Mercor / Delve / Berrie AI**, No. 6:26-cv-00143-H (N.D. Tex., First Amended Complaint April 2026), advances the novel theory that fraudulent SOC 2 certifications by Delve created a foreseeable chain of harm running through LiteLLM into Mercor and on to data subjects Captain Compliance and to "John Doe LLM Companies 1–10" — putting plenary developer indemnification of contractor failures squarely in front of a federal court for the first time. White & Beltran additionally alleges Mercor's Insightful screen-monitoring software indiscriminately captured proprietary code, attorney-client communications, and primary-employer system content, Compliancehub and that Mercor "sold, licensed, or otherwise provided contractor data … for use in training and developing large language models" compliancehub while contractually prohibiting disclosure of the very materials its surveillance was engineered to capture. PYMNTS

Why it matters: it demonstrates **liability latency** — a 40-minute compromise Second Talent of one OSS maintainer's PyPI credentials simultaneously implicating contractor labor law (BIPA, AIVIA, FCRA), supply-chain security, compliance-certifier integrity, and frontier-lab proprietary IP. It exposes the **nth-party dependency problem**: Mercor was not a Delve customer; LiteLLM was; Mercor relied on LiteLLM's Delve-issued certifications. It breaks the assumption that a SOC 2 certification insulates the relying party — the complaints argue that buying a SOC 2 in days for $6K–$15K StrikeGraph is itself a due-diligence red flag. **All allegations are unproven; Mercor disputes them; motion-to-dismiss disposition will narrow or expand the canonical-case status.**

Insurance and the liability gap

Gallagher Re / MIT / Testudo Global (early 2026) found GenAI lawsuits grew 978% from 2021 to 2025. Risk & Insurance Standard policies map poorly: cyber excludes IP

infringement, defamation, hallucinations causing financial loss; Risk & Insurance tech E&O is built for vendors not deployers; Risk & Insurance product liability covers physical-device AI but excludes algorithmic financial harm and discrimination; Risk & Insurance D&O is being tested by AI-washing securities suits (SEC settled with Delphia and Global Predictions, March 2024). AI-specific products: **Munich Re aiSure™** (2018, parametric-style, Klover with Mosaic partnership 2025 providing up to EUR/USD/CAD 15M); ReinsuranceNe.ws **Armilla** (2025, ongoing model-quality assessments, backed by Chaucer and Axis); Risk & Insurance **Testudo** (January 2026, Defense defending litigation including copyright and bodily-injury). Risk & Insurance Gallagher Re flags **systemic accumulation**: a critical flaw in one widely adopted foundation model could trigger correlated claims across thousands of unrelated policyholders Risk & Insurance — analogized to "silent cyber" of the early 2010s.

Software liability — where it lands

ONCD's March 2023 National Cybersecurity Strategy Pillar 3 and the 2023 Implementation Plan Initiative 3.3.1 directed exploration of a software liability framework by 2Q FY24; CISA Director Easterly (Carnegie Mellon, February 2024) and National Cyber Director Coker (February 2024) Cybersolarium escalated the rhetoric; no liability legislation has passed Congress as of May 2026. The Trump administration's AI Action Plan (July 23, 2025) and EO 14179 (January 23, 2025) Workforcebulletin +2 signal a deregulatory pivot: in **December 2025 the FTC reopened and set aside its 2024 Rytr consent order** Federal Trade Commission as the first AI Action Plan implementation, narrowing AI enforcement. The EU AI Liability Directive was withdrawn from the 2025 Commission Work Programme on February 11, 2025 IAPP and formally withdrawn in the Official Journal on October 6, 2025 (C/2025/5423); EAPIL what filled the gap is the revised **Product Liability Directive (Directive (EU) 2024/2853)** extending defective-product strict liability to software and AI systems including psychological-health and data-loss damages. **For the foreseeable U.S. horizon, AI liability will be judge-made through litigation, not statute** — Bartz, NYT v. OpenAI, Ananthula v. Mercor, FDA SaMD, FTC §5, BIPA/AIVIA, FCA. A v1 Pillar 5 framework should architect the auditable evidence chain assuming common-law negligence will define the standard of care.

Anthropic v. Department of War — the regulator-leverage edge case

A 360-accountability framework must contemplate government as adversarial counterparty. **Anthropic, PBC v. Department of War et al.**, No. 3:26-cv-02197 (N.D. Cal., filed March 9, 2026) Pearl Cohen tests whether the government can punish an AI developer for refusing "any lawful purpose" use. Judge Rita F. Lin granted preliminary injunction Wikipedia March 24, 2026: "The Department of War's records show that it designated Anthropic as a supply chain risk because of its 'hostile manner through the

press.' Burr & Forman Punishing Anthropic for bringing public scrutiny to the government's contracting position is classic illegal First Amendment retaliation." Wikipedia The D.C. Circuit denied Anthropic's stay April 8, 2026, ordering "substantial expedition." CNBC Implication: a v1 framework must specify the developer's **red-line preservation rights** as a contractual matter and an evidence-grade Responsible Scaling Policy that survives procurement coercion.

Architectural control primitives

The deployable Pillar 5 substrate: **cryptographically signed model card** at each release with hash in an append-only transparency log; **SLSA L3 provenance** with in-toto Layout signed by release authority and lockfile-pinned dependencies (the Mercor lesson — organizations using `poetry.lock` or `uv.lock` were completely protected from malicious LiteLLM StrikeGraph 1.82.7/1.82.8); **CycloneDX or SPDX SBOM/AIBOM** for every artifact including training-data lineage where compatible with confidentiality; **compliance-certifier engagement-letter attestation** (a direct response to the Delve scandal); CMMC-equivalent SPRS affirmations for all contractors; **per-deployer high-impact determination** under M-25-21 §5 with appropriate-agency-official sign-off; **append-only inference-and-prompt log** with cryptographic checkpointing (NYT v. OpenAI established January 5, 2026 that 20M anonymized ChatGPT logs are discoverable NatLawReview — logs are now litigation evidence by default); incident-disclosure pipeline to GPAI Code Measure 7.7 / Article 55(1)(c), CAISI, deployer agency / OMB, and end users where notifiable; whistleblower channel with NDA carve-outs preserving National Whistleblower Center SEC, DoD-IG, agency-IG, and state-public-policy disclosures; insurance attestation at developer + deployer tiers.

Regulator interfaces and end-user accountability

CAISI, post the June 3, 2025 Harvard Kennedy School rebrand (Lutnick: "innovators will no longer be limited by these standards"), FedScoop Broadband Breakfast is **an evaluation supplier, not a regulator** — focused on cybersecurity, biosecurity, and chemical-weapons risks, National Institute of Standards and SSTI plus adversary-system assessments and international standards leadership. SSTI CAISI signed an MOU with GSA National Institute of Standards and in March 2026 for the USAi platform. NIST The OMB AI use-case inventory chain runs M-25-21 → CAIO Governmentcontractslawblog → AI Governance Board Homeland Security (deadline July 2, 2025) DHS → annual inventory (FY25 due to OMB December 22, 2025; agency public posting January 28, 2026) GitHub → minimum risk-management practices for high-impact AI by April 3, 2026. Homeland Security Sectoral regulators: FTC §5 (Operation AI Comply, Federal Trade Commission narrowed under Ferguson); FDA SaMD with 2024 Predetermined Change Control Plan; CFPB Reg B / ECOA algorithmic-bias enforcement; EEOC May 2023 technical assistance; SEC AI-washing enforcement; state AGs (Texas /

Pieces Technologies September 2024) and Illinois BIPA / AIVIA private rights of action.

End-user accountability has historically been treated as rights-only. A v1 framework should treat the end user as both rights-holder and obligation-bearer: acceptable-use compliance (no jailbreak attempts, no output-misrepresentation), disclosure of AI use to downstream third parties, reasonable-care duty in regulated decisions, and honest reporting of AI errors back to deployers. The "Right to Warn" letter (June 4, 2024, 13 OpenAI/Google DeepMind employees, Time Lessig as pro bono counsel) Time frames the whistleblower architecture: end NDAs that silence safety concerns; anonymous internal reporting reaching board, regulators, or relevant entities; foster open criticism; refuse retaliation when other processes have failed. National Whistleblower Center

Critical view

The biggest gaps: compliance-certifier liability (no statute or regulation directly allocates liability to a SOC 2 / ISO / CMMC C3PAO certifier whose attestation is foreseeably relied upon downstream — White & Beltran is the first U.S. complaint to plead this); open-source library/gateway vendor liability (Section 230 doesn't cover a malicious package; the EU Cyber Resilience Act applies only with monetization carve-outs; the U.S. has no analog); developer obligations to vet contractor labor practices (no federal rule today requires Anthropic, OpenAI, or Meta to vet contractor BIPA / AIVIA / FCRA compliance — Mercor's Doe AI Labs defendants will test whether such a duty exists in negligence); end-user accountability primitives (no architectural primitive equivalent to "user-AUP-signed log" required by federal procurement); procurement-coercion limits on developer red lines (Anthropic case is filling this by litigation); AI liability legislation absence (state laws are filling unevenly); auditable nth-party dependency disclosure (GSAR 552.239-7001 captures "Service Providers" broadly Statt +2 but provides no SBOM-grade primitive); cross-border evidence-chain conflicts (NYT discovery may conflict with GDPR Article 48); and insurance accumulation for shared foundation models. **The EU is the more durable compliance anchor** as of May 2026 — AI Act + GPAI Code + revised PLD + EU SEND submission portal create more stable Pillar-5 regime than U.S. federal law.

Cross-cutting synthesis

Five-by-five interaction matrix

The pillars are not orthogonal. Each pair has a complement effect, a tension, or both, and the Mythos / Glasswing / Mercor incident chain illuminates them concretely.

P1 ↔ P2: Pillar 1 sets the policy that Pillar 2 operationalizes (incident-response

playbooks pre-drafted as part of baked-in governance). The risk: P1 compliance theater (the Delve case) defeats P2 readiness. The two pillars must be jointly tested or both decay.

P1 ↔ P3: Pillar 1 mandates redundancy in design; cost-driven minimization pressures pull P3 against P1. ISO 42001 A.4.5 (system and computing resources) plus NIST 800-53 CP family are the hinge.

P1 ↔ P4: Pillar 1 must specify the zero-trust architecture explicitly or Pillar 4 reverts to perimeter habits. ISO 42001 A.6.2.5 (deployment) plus NIST AC-2 / IA-5 are the binding controls.

P1 ↔ P5: This is the **standards spine**. Every Annex A control of ISO 42001 either establishes a thing (P1) or accounts for it (P5). NIST AI RMF GOVERN function Palo Alto Networks fuses both. NIST 800-53 PT and AU families fuse here.

P2 ↔ P3: This is the **resilience axis**. P2 is detection and response; P3 is structural survivability. Mercor is a P3 failure (the LiteLLM gateway was a single chokepoint) that P2 then failed to detect (4TB exfil ran undetected during attacker dwell). Assuming breach with a single point of failure equals guaranteed catastrophic loss.

P2 ↔ P4: Mutually reinforcing. Zero trust generates the telemetry assumed-breach exploits (SI-4 + AC-4). Conversely, P4 without P2 produces brittle, unresponsive deny-by-default postures.

P2 ↔ P5: P2 incident-disclosure cadence (ISO 42001 A.8.4) is meaningless without P5 attribution; conversely P5 audit logs must survive the assumed breach (NIST 800-53 AU-9 protection of audit information).

P3 ↔ P4: Antagonistic. P3 (multiple credentials, multiple paths) without P4 enlarges the attack surface — the Mercor LiteLLM gateway had broad lateral access *because* it was the convergence point of many systems. P4 prunes the redundancies P3 introduces by authorizing per-path.

P3 ↔ P5: Distributed systems complicate attribution; P3 must include P5-grade tracing (OpenTelemetry, SPIFFE workload identity) or accountability is lost in the redundancy.

P4 ↔ P5: P4 generates per-action authentication events; P5 makes them durable, queryable, disclosable. The CAISI February 17, 2026 agent-identity work explicitly couples P4+P5 (OAuth 2.0 audience claims plus immutable logs).

Pillar contribution to the Mythos / Glasswing / Mercor incident chain

Mapped link by link, **Pillar 4 is the load-bearing pillar**. Eight of the twelve breach links would have been mitigated by zero-trust controls; the dominant single failure (link 9:

active broad-scope contractor credentials in Anthropic's vendor environment) is purely a P4 failure. **Pillar 1** would have prevented links 1, 3, 7, 8, 11 (signed releases, dependency pinning, biometric data minimization, endpoint-as-secret hygiene, staged release governance). **Pillar 2** would have contained links 6, 10, 11, 12 (egress-volume anomaly detection, canary alerts on first preview access, breach-window minimization). **Pillar 3** would have made links 3, 5, 7 survivable (not all eggs in one OSS gateway, not all PII in one bucket, not all access mediated by one credential type). **Pillar 5** would have made links 1, 2, 8, 12 attributable and actionable (provenance/SBOM means link 2 is traceable; immutable audit logs make link 12 disclosable; supplier accountability would have surfaced Delve "fake compliance" before LiteLLM trusted it).

Mapping each pillar to durable substrates

To NIST AI RMF: P1 ↔ GOVERN Palo Alto Networks (GV.1, GV.2, GV.3, GV.4) and MAP (MP.1, MP.2); P2 ↔ MEASURE (MS.2.6, MS.2.7) and MANAGE (MG.4.1, MG.4.3); P3 ↔ MEASURE (MS.2.5, MS.2.6) and MANAGE (MG.2.1); P4 ↔ MEASURE (MS.2.7) and MANAGE (MG.4.1); P5 ↔ GOVERN (GV.2, GV.5, GV.6) and MANAGE (MG.3, MG.4.3).

To NIST 800-53 Rev 5 control families: P1 → PL, PM, PT, SA (system development), CM, MP; P2 → IR, AU, SI, CP-9/10, RA; P3 → CP, SC-5/6/36/37, SR; P4 → AC, IA, SC-7/39, AU; P5 → AU, CA, PM-12/30, PS-7, SR-3/6. Each family carries multiple controls germane to a specific pillar; Isora GRC the matrix is one-to-many in both directions.

To ISO/IEC 42001 Annex A: P1 → A.2 (policies), A.5 (impact assessment), A.6 (lifecycle), A.7 (data); P2 → A.6.2.6 (operation/monitoring), A.8.4 (incident communication); P3 → A.4.5 (system resources), A.7.5 (data provenance); P4 → A.9.4 (intended use), A.10.3 (suppliers); P5 → A.3 (internal organization), A.8 (information for interested parties), A.10 (third-party).

To FedRAMP authorization artifacts: P1 → SSP, PIA, Rules of Behavior, SCRM Plan; P2 → IR Plan, ConMon deliverables, SCN (replacing SCRs); P3 → ISCP, BIA, Backup tests; P4 → DIAS, control implementation for AC/IA/SC; P5 → POA&M, ATO letter, ConMon monthly scans. FedRAMP 20x (March 2025–2026) replaces Word/PDF SSPs with machine-readable OSCAL, Cabrillo Club KSIs, ADS, and the Persistent Validation and Assessment Standard — all of which restructure how Pillar evidence is rendered.

To GSA AI clause (draft GSAR 552.239-7001, March 6, 2026): the clause's six core obligations Foxrothschild map directly — P1 (use disclosure within 30 days), Foxrothschild P3 ("American AI Systems" requirement, Burr & Forman which is also a concentration constraint), P5 (Service Provider flow-down, Statt government audit rights, IP/Custom Developments), Gibson Dunn P4 (no-refusal output requirement BUY.GSA.GOV which has tension with P4 capability scoping), with the take-it-or-leave-it 60-day MAS acceptance window. Mondaq Passle

To CAISI evaluation methodology: capability evaluations align to P2 (red-teaming) and P5 (evaluation reports as evidence); adversary-system assessments to P5 and P2; the AI Agent Standards Initiative deliverables (Agent Interoperability Profile Q4 2026, SP 800-53 agent overlays forthcoming) Lab Space target P4 directly with P5 secondary.

Genuine gaps where pillars create new requirements

The framework adds new content rather than restating existing content in these specific places: **AIBOM standardization** (no federal mandate as of May 2026); **agent/non-human-entity identity at federal scale** (FICAM doesn't address; CAISI Initiative is the federal response but normative spec not yet delivered); **pre-deployment evaluation registration** (no federal analog to ClinicalTrials.gov); the named architectural primitive **"governance-by-design"** (federally unnamed); **continuous attestation post-M-26-05 rescission**; **cross-pillar evidence integration** in a single audit-grade artifact; **compliance-certifier liability** (post-Delve novel theory); **open-source-library-vendor liability** (post-LiteLLM novel category); **developer-tier vetting of contractor labor practices**; **architectural primitives for end-user accountability**; **evidentiary inference-and-prompt logging that survives litigation hold**; and **explicit red-line-preservation contractual rights** for developers facing procurement coercion.

Durable spine versus replaceable surface

For each pillar, the v1 framework should distinguish **durable spine** (what does not change across administrations) from **replaceable surface** (what is administration- or vendor-specific).

P1 spine: NIST SP 800-160 Vol 1 Rev 1, NIST SP 800-218 + 800-218A, NIST Privacy Framework, NIST AI RMF, ISO/IEC 42001, FICAM, the PIA statutory regime under E-Gov Act §208. **P1 surface**: which OMB memo is operative (M-24-10 → M-25-21; MIstrategies M-22-18/M-23-16 → rescinded by M-26-05); Inside Government Contracts whether the CISA Common Form is required; specific signatory counts on the Secure-by-Design Pledge.

P2 spine: NIST SP 800-207, MITRE ATT&CK + ATLAS, OWASP LLM Top 10, the seven 800-207 tenets, the assume-breach doctrine itself. **P2 surface**: specific OMB FY-deadline language; specific DoD ZT Strategy version (1.0 → 2.0); CTEP catalog contents.

P3 spine: NIST SP 800-160 Vol 2 Rev 1 (14 techniques), NIST SP 800-34, NIST SP 800-161 Rev 1, the SR control family, the cyber-resilience design principles, the financial-sector Treasury/FFIEC concentration vocabulary, SBOM/AIBOM/SLSA/Sigstore primitives. **P3 surface**: market-share figures (Anthropic 40% / OpenAI 27% / Google 21% Menlo Ventures will move); specific cross-shareholdings; specific incidents.

P4 spine: NIST SP 800-207 + 800-207A, the seven tenets, PE/PA/PEP, SPIFFE / SPIRE, OAuth 2.0 / OIDC / RFC 8693 / RFC 9728 / RFC 8414 / RFC 7591, mTLS, confidential computing primitives. **P4 surface**: specific CVE numbers; specific MCP version status; vendor product names (Microsoft Entra Agent ID, Okta for AI Agents); the M-22-09 deadline status; CAISI deliverable-by-deliverable timing.

P5 spine: in-toto / SLSA / Sigstore, append-only transparency logs, CycloneDX / SPDX, EU AI Act provider/deployer split, NIST AI RMF GOVERN, FAR/DFARS flow-down architecture, CMMC 2.0 32 CFR Part 170, FRE 901/902 authentication, SEC / DoD-IG / agency-IG / state-public-policy whistleblower channels, EU revised PLD strict-liability extension. **P5 surface**: which specific litigation is pending (Mercor cluster, Anthropic v. DoW, Bartz, NYT v. OpenAI, GEMA, Getty); whether AILD was withdrawn (it was); FTC enforcement posture; insurance product names.

Specific design decisions the v1 framework will need to make

(1) Pillar primacy under contention. When P3 (redundancy) and P4 (zero trust) conflict — does the framework default to authorizing all redundant paths under P4, even when P3-mandated diversity expands attack surface? The Mercor incident argues P4 wins.

(2) Compliance-certifier liability stance. Does v1 require that engaged certifiers publish signed engagement-letter attestations of audit scope, auditor independence, and evidence-review depth — and that contractors warrant these to the federal buyer? White & Beltran tests this in court; the framework can pre-empt by contractual requirement.

(3) AIBOM mandate. Does v1 require CycloneDX ML-BOM 1.5+ or SPDX 3.0 AI/Dataset profiles at every release, signed via Sigstore with Rekor entry, even though no federal mandate exists? This is the highest-leverage Pillar 3 + Pillar 5 control.

(4) Inference-and-prompt log evidentiary status. Does v1 require that all inference and prompt logs be produced as cryptographically checkpointed append-only artifacts that meet FRE 901/902 self-authentication? NYT v. OpenAI's January 5, 2026 ruling NatLawReview makes this litigation-relevant.

(5) Agent identity stack. Pending CAISI's AI Agent Interoperability Profile (Q4 2026), which composition does v1 require? The defensible answer: SPIFFE for workload identity HashiCorp + RFC 8693 for human-to-agent delegation chains Gravitee + AuthZEN for fine-grained PDP Curity + MCP authorization spec for tool authorization + Microsoft Entra Agent ID or Okta for AI Agents at the management plane — knowing the framework's evidence model must absorb whatever CAISI publishes.

(6) Concentration thresholds. Does v1 quantify concentration (e.g., no single vendor

>40% of inference, no single foundation model >50% of safety-critical decisions) or remain qualitative (per Treasury 2023's acknowledgment that no agreed definition exists)? Pifsinternational Quantification is more enforceable; qualification is more durable.

(7) Developer red-line-preservation rights. Does v1 specify a contractual primitive that survives procurement coercion attempts of the kind Anthropic faced? This is novel federal-contracting territory.

(8) End-user accountability primitive. Does v1 require an "AUP-signed log" architectural primitive at the federal-employee and contractor tier — closing the loop on Pillar 5's end-user role rather than leaving end users as rights-only?

(9) Cross-administration durability. Given EO churn (14110 → 14148 Wikipedia → 14179 → AI Action Plan → 14318 / 14319 / 14320 → M-25-21 / M-25-22 / M-26-04 → rescissions of M-22-18 / M-23-16 by M-26-05), Inside Government Contracts does v1 anchor primarily to NIST + ISO + procurement contracts (durable) or to OMB memoranda (replaceable)? The defensible answer: durable spine first, with OMB-memo overlays modularized and dated.

(10) Evidence pipeline architecture. Does v1 require a single regulator-ready evidence pipeline that produces, per AI use case: PIA + AIIA + Model Card + AIBOM + SBOM + SLSA provenance + 3PAO assessment + ConMon deliverables + use-case inventory entry + incident reports + whistleblower-channel records + insurance attestation, all cross-referenced by hash and stored in append-only logs? This is the productizable core of an AI governance platform venture.

Conclusion: the spine, the surface, and the open work

The five pillars — governance baked in, assumed breach, no single point of failure, zero trust throughout, 360 accountability — are not a marketing taxonomy. They are the smallest set of architectural commitments that, if jointly enforced by the deployment substrate, produce a federal AI system that survives the threat model the Mythos / Glasswing / Mercor incident chain has just made empirical. **Each pillar traces to a durable federal spine** (NIST SP 800-160, 800-207, 800-161, 800-218, 800-218A, the AI RMF, ISO/IEC 42001, the EU AI Act, FAR/DFARS/CMMC). **Each pillar produces evidence-grade artifacts** (signed model cards, AIBOMs, SLSA provenance, PE decision logs, append-only inference logs, regulator-ready submissions). **Each pillar contains genuinely new requirements** — AIBOM standardization, agent identity, pre-deployment evaluation registration, governance-by-design as an architectural primitive, compliance-certifier liability, end-user accountability primitives — that current federal

frameworks have not yet specified and where the v1 framework adds rather than restates.

The most important May-2026 facts the framework must reflect: M-25-21's high-impact-AI **April 15, 2026 comply-or-terminate deadline**; M-26-05's rescission of centralized secure-development attestation; CAISI's June 2025 reframing from safety to standards/secure innovation; CAISI's **February 17, 2026 AI Agent Standards Initiative** with Q4 2026 Interoperability Profile target; the OX Security April 2026 MCP disclosure and the heyuan110 30-CVEs-in-60-days documentation; the Anthropic v. Department of War preliminary injunction; the EU AI Liability Directive's October 6, 2025 official withdrawal and the revised PLD picking up; the FedRAMP 20x transition with Phase 2 Moderate pilots running through Q3–Q4 2026; FedRAMP authorization data shifting to OSCAL, KSIs, and the Persistent Validation and Assessment Standard; the Mercor litigation cluster (Ananthula, Gill, Deboni, Esson, White & Beltran) testing 360-accountability theories of liability for the first time in federal court; Bartz v. Anthropic's $1.5B copyright settlement final approval hearing May 14, 2026; and NYT v. OpenAI's discovery order making 20M anonymized ChatGPT logs litigation evidence by default.

The framework's defensible posture is **anchored in the durable spine, modular at the replaceable surface, and explicit about its open work**. The open work is not small: agent identity normative specs, AIBOM federal mandate, compliance-certifier liability allocation, end-user accountability primitives, cross-pillar evidence integration, and quantitative concentration thresholds. These are exactly the spaces in which a v1 governance framework — and the consulting/platform venture that delivers it — adds the most differentiated value, because the federal substrate has not yet specified them and the courts and regulators are now writing them, in real time, through pending litigation and forthcoming CAISI deliverables. A framework that builds to the durable spine, lights up the gaps explicitly, and produces evidence-grade artifacts for each control will be defensible today, traceable tomorrow, and revisable as the surface shifts.